

ICS 33.030

CCS M 21

团体标准

T/TAF 209.4—2024

移动互联网应用程序（APP）合规开发管理 测评规范 第4部分：代码审计

Evaluation specification for compliance development of mobile Internet
application—Part 4: Code audit

2024-02-23 发布

2024-02-23 实施

电信终端产业协会 发布

目 次

前言 II

引言 III

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 缩略语 1

5 概述 2

 5.1 审计目标 2

 5.2 审计原则 2

 5.3 审计场景 2

6 审计管理要求 2

 6.1 组织制度 2

 6.2 审计流程 3

 6.3 审计人员 3

 6.4 审计工具 3

7 测评方法 4

附录 A（资料性） 代码审计要点 5

附录 B（资料性） Android APP 合规编码指南 7

附录 C（资料性） iOS APP 合规编码指南 8

参考文献 9

前 言

本文件按照 GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

本文件是T/TAF 209《移动互联网应用程序（APP）合规开发管理测评规范》的第4部分。T/TAF 209已经发布了以下部分：

- 第1部分：总则；
- 第2部分：需求设计；
- 第3部分：功能测试；
- 第4部分：代码审计；
- 第5部分：对外接口管理；
- 第6部分：应用编程（API）管理；
- 第7部分：更新升级管理；
- 第8部分：数据使用管理；
- 第9部分：算法模型；
- 第10部分：人员能力；
- 第11部分：能力成熟度评估。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由电信终端产业协会提出并归口。

本文件起草单位：中国信息通信研究院、北京奇虎科技有限公司、北京微梦创科网络技术有限公司、蚂蚁科技集团股份有限公司、小米通讯技术有限公司、维沃移动通信有限公司、联想（北京）有限公司、荣耀终端有限公司。

本文件主要起草人：姚一楠、谭泽辉、朱凯、王俊、桑明臣、任海峰、张睿、林冠辰、姚鹤、张丕鑫、徐曼、赵盈洁、李汝鑫、赵晓娜、战蕾蕾。

。

引 言

T/TAF 209旨在对APP开发流程、功能模块、工程管理等提出合规开发管理要求，拟由11部分构成。

——第1部分：总则。目的在于给出规范移动互联网应用程序（APP）合规开发的总体原则和要求。

——第2部分：需求设计。目的在于提出规范APP需求设计环节的相关合规开发要求。

——第3部分：功能测试。目的在于规范移动互联网应用程序（APP）在合规开发阶段满足功能测试的标准要求。

——第4部分：代码审计。目的在于规范APP代码审计过程，提升代码安全管理能力。

——第5部分：对外接口管理。目的在于规范APP对外接口的合规开发和使用管理，提升合规能力。

——第6部分：应用编程接口（API）管理。目的在于规范APP在开发过程中对于API的使用，提升合规能力。

——第7部分：更新升级管理。目的在于规范APP合规开发在更新升级阶段的要求，提升APP更新升级管理能力。

——第8部分：数据使用管理。目的在于规范APP在合规开发过程中数据使用的合规管理，提升数据使用合规管理能力。

——第9部分：算法模型。目的在于规范APP合规开发在算法模型方面的要求，提升APP算法模型开发的合规管理能力。

——第10部分：人员能力。目的在于规范APP在合规开发过程中的人员能力管理。

——第11部分：能力成熟度评估。目的在于规范APP在合规开发管理过程中的能力成熟度评估。

移动互联网应用程序（APP）合规开发管理测评规范 第4部分：代码审计

1 范围

本文件规定了移动互联网应用程序在合规开发管理过程中的针对个人信息安全、数据安全的代码审计要求，包括了审计管理要求和审计内容要求。

本文件适用于移动互联网应用程序开发者所在组织针对自身产品进行代码合规自评估，同时也适用于第三方机构、合作方等实施代码审计。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 39412—2020 信息安全技术 代码安全审计规范

3 术语和定义

下列术语和定义适用于本文件。

3.1

代码审计 code audit

对代码进行分析，以发现代码安全缺陷或违反代码安全规范的动作。

[来源：GB/T 39412—2020，3.1.1，有修改]

4 缩略语

- AES：高级加密标准（Advanced Encryption Standard）
- AK：访问密钥（Access Key）
- APP：移动互联网应用程序（Mobile Internet Application）
- ARC：自动引用计数（Automatic Reference Counting）
- ASLR：地址空间布局随机化（Address Space Layout Randomization）
- CBC：密码块链模式（Cipher Block Chaining）
- CFB：密码反馈模式（Cipher Feedback）
- ECB：电子密码本模式（Electronic Codebook）
- HTTPS：超文本传输安全协议（Hypertext Transfer Protocol Secure）
- PIE：位置无关可执行文件（Position Independent Executable）
- PKCS5Padding：公钥密码标准#5填充（Public Key Cryptography Standards #5 Padding）

SDK: 软件开发工具包 (Software Development Kit)
SK: 秘密密钥 (Secret Key)
SQL: 结构化查询语言 (Structured Query Language)
SSL: 安全套接字层 (Secure Sockets Layer)
TLS: 传输层安全协议 (Transport Layer Security)
URI: 统一资源标识符 (Uniform Resource Identifier)
URL: 统一资源定位符 (Uniform Resource Locator)

5 概述

5.1 审计目标

在APP开发过程中采用审计方式发现并纠正代码安全缺陷、合规风险,以保障移动互联网应用程序安全性和稳定性,满足个人信息保护、数据安全相关法律法规要求。

5.2 审计原则

代码审计过程应遵循以下原则进行:

- 保密原则。在审计过程中,应采取安全措施保证被审计代码和审计结果不泄露给任何无关单位和个人。
- 客观公正原则。应保证审计活动的客观公正,审计结果不受任何利益冲突或主观偏见的影响,以确保审计结果的可信度。
- 规范化原则。实施审计时应依据成熟的代码规范、国内外标准或最佳实践,审计人员应具备足够的专业能力,审计过程应充分记录,以确保审计的全面性、一致性和准确性。
- 适度安全原则。在安全策略制订上,考虑安全机制合理性,对重点资源进行重点保护。在保证安全的前提下,应尽量减少安全机制的复杂度,增加可操作性。

5.3 审计场景

代码审计分为内部审计和外部审计,内部审计由组织内部负责合规或质量管理相关人员组织开展,外部审计则由第三方开展。在满足保密原则前提下,可在以下场景安排代码审计工作:

- a) APP上线前。在APP发布给公众或第三方之前,应进行内部审计,以发现开发团队可能忽略的安全问题并提高APP的安全性和可靠性。
- b) APP功能发生较大变更前。在APP业务功能发生重要添加或涉及安全问题更新时,应进行内部审计,确保发现新业务代码缺陷,验证原有安全漏洞是否已被修复,同时没有引入新的安全问题。
- c) 安全合规事件发生后。在确认APP遭受安全威胁或已经发生安全或合规事件后,应进行内部审计,宜增加外部审计,及时解决问题减少损失。
- d) 定期审计。组织宜根据具体情况在APP开发生命周期内定期开展代码审计,维持APP合规性。
- e) 合规要求。满足相关法律法规要求应开展代码审计的场景。

6 审计管理要求

6.1 组织制度

组织对代码审计制度的管理包含以下要求:

- a) 应建立代码审计管理制度,明确审计场景、组织部门、执行部门、审计流程、依据标准等内容;
- b) 应建立安全开发规范,明确编码要求,包括但不限于代码安全要求、代码合规要求、资源使用要求、配置管理要求等;
- c) 应将审计相关制度、开发规范、指导书等文件在组织内部公示,并定期对于代码审计人员、APP 开发人员进行培训考核。

6.2 审计流程

代码审计流程包括准备阶段、实施阶段、总结阶段,组织在审计过程中包含以下要求:

- a) 应在准备阶段明确本次代码审计目的、范围、时间安排、审计负责人、开发者或 APP 负责人等基本信息,并应准备好以下内容用于审计实施:

- 待审核代码基本信息表;

注1:基本信息可包括代码版本、所属模块、编程语言、第三方组件、变更记录、相关安全文档和注释等。

- 待审核代码包;
- 审计工具;
- 审计要点列表;
- 其他辅助开展审计工作的文档,如保密协议、会议记录单等。

注2:辅助文档可根据组织安全审计实际情况选择准备,如进行外部审计则应与外部审计单位签署保密协议,如仅采用内部审计则可不准备该类文件。

- b) 应在准备阶段选择合适的代码审计工具,确保其配置正确并处在安全运行环境下,以保证审计实施的安全性;
- c) 应在实施阶段采用人工审计和工具审计相结合的方式检查代码安全缺陷,对于开源代码或外包开发部分应重点审计,审计要点可参考附录 A。
- d) 应在总结阶段出具审计结果,审计人员与开发人员应共同确认代码安全缺陷、整改建议、审计结论等,出具正式审计报告并留存。
- e) 应对于审计问题进行改进跟踪,对于代码有效变更进行记录,对于整改后的代码,应通过再次审计确认问题已经解决;
- f) 应采用安全措施防止非授权人员访问、篡改审计相关数据,保证审计结果完整性。
- g) 应保留每一次审计过程记录和相关文档,便于跟踪溯源。

6.3 审计人员

组织对代码审计人员的管理包含以下要求:

- a) 应指派熟悉 APP 安全、合规相关法律法规要求及技术措施以及组织审计管理制度的人员从事代码审计工作;
- b) 人员应具备相对独立性,组织应安排专门负责合规或质量管理相关人员开展审计工作,不应包含参与 APP 开发相关技术人员;
- c) 应持续针对审计人员组织安全合规培训,培训内容包括但不限于法律法规、政策、标准和行业规范、组织管理制度、安全技术、职业操守等;
- d) 应通过建立管理手段保证审计人员能客观呈现代码安全缺陷且对于审计过程保密,管理手段可包括复审、监督、举报等。

6.4 审计工具

组织对代码审计工具的管理包含以下要求:

- a) 应选择适当的代码审计工具实施审计工作,审计工具应满足以下要求:

- 支持对于常见代码审计要点的自动化审计，审计要点可参考附录 A；
 - 支持代码审计策略配置，如设定阈值、数据类型、黑白名单等；
 - 支持对于审计过程进行详细记录，并生成审计报告，记录生成内容包括但不限于：审计环境和配置信息、审计人员操作记录、发现缺陷类型、缺陷位置、严重程度、修复建议等；
 - 具备安全机制保证自身安全，确保审计过程数据的保密性、完整性和可用性；
- b) 应定期更新审计工具，确保审计策略与最新的合规要求保持一致。

7 测评方法

对于组织的代码审计管理能力测评可采用资料审查、技术验证、人员访谈的方式进行，从而判断组织是否符合6要求。测评方法对应关系见表1。

表1 合规开发管理要求与测评方法对应关系表

要求条款	测评方法		
	资料审查	技术验证	人员访谈
6.1a)	√	—	—
6.1b)	√	—	—
6.1c)	√	—	√
6.2a)	√	—	—
6.2b)	√	√	—
6.2c)	√	√	√
6.2d)	√	—	—
6.2e)	√	—	—
6.2f)	√	√	—
6.2g)	√	—	—
6.3	√	—	√
6.4	√	√	—

其中：

- a) 组织应提供代码审计相关文档配合资料审查，包括但不限于组织架构介绍、代码审计制度、安全开发规范、人员培训考核记录、历史审计报告、相关资质证明等；
- b) 测评过程应保证客观公正，且应采取保密措施防止相关文档、沟通信息等被非授权人员访问。

附录 A
(资料性)
代码审计要点

表A. 1给出了APP开发中对于数据安全、个人信息保护常见合规检查内容，组织在实施审计过程中可根据审计目的，最新合规要求对审计内容进行增减。

表A. 1 代码审计要点

一级分类	二级分类	要点描述
用户认证与授权	多因素认证	对于安全级别较高的 APP（如涉及金融支付类业务），审计人员应检查 APP 是否采用多因素身份认证方式
	认证绕过	检查用户访问认证的方式，确保用户只能通过应用提供的认证途径进行认证，检查应用是否容易受到认证绕过攻击或是否存在逻辑上绕过漏洞，如通过修改请求或跳过关键认证算法来访问受限资源或进行受限操作。
	授权和权限检查	检查APP是否具备访问控制策略且正确实现，确保用户只能访问其所需的资源和功能。
安全输入	输入验证	检查 APP 是否对于用户输入的信息进行验证和识别，以防止常见的安全问题，如 SQL 注入和跨站脚本攻击。
	输入防护	检查APP是否存在对用户输入的认证信息的安全性防护能力，可采用的方式包括但不限于：字符串加密、键盘监听防范、自定义软键盘等防护方案，防止用户输入的信息被第三方应用获取。
会话管理	会话超时	检查 APP 是否在用户认证成功后有实施合适的会话管理，具备会话超时设置和重新认证机制，确保用户在一定时间后需要重新进行身份认证，避免会话劫持和滥用。
	会话注销	检查APP是否存在会话注销管理功能，当用户退出登录状态时，客户端应和服务器进行通信以保证退出的及时性，避免用户凭证泄露后，会话存在滥用的风险。
数据加密和保护	安全的通信协议	检查APP是否使用了安全的通信协议来传输用户凭据和敏感数据，如采用HTTPS且TLS版本大于1.2。
	数据加密存储	检查APP在本地存储用户凭据和敏感信息时是否采用适当的加密保护，可采用安全密码算法进行加密存储，或采用安全的存储方式（如：Android Keystore）。
	数据加密传输	检查APP是否在传输用户凭据和敏感信息前使用了安全的加密算法对数据进行加密，不存在明文传输的情况。
	加密模式	检查APP是否使用了安全的加密算法、加密模式进行数据加密。
	硬编码风险	检查APP是否存在敏感信息硬编码风险。APP不应在代码中硬编码密钥、口令、用户凭据等敏感信息，防止攻击者通过反编译等手段得到敏感信息。

表A.1 代码审计要点（续）

一级分类	二级分类	要点描述
安全配置	APP安全配置	检查 APP 是否采用了正确的安全配置。如 AndroidManifest.xml 中 allowBackup 属性应为 false，Debuggable 属性应为 false，防止被攻击者恶意利用造成数据泄露等风险。
	Webview安全配置	检查WebView是否采用了正确的安全配置。如启用跨域策略、URL来源验证、缓存设置等，防止被攻击者利用出现跨站脚本攻击、远程代码执行等安全问题。
第三方组件	第三方SDK集成	检查APP客户端中集成的第三方SDK，确保不应存在已知的问题，合规问题。对于旧版本的第三方SDK应该及时进行更新升级。
个人信息保护	最小权限	检查APP是否合理申请所需的敏感权限，确保业务功能所使用的权限符合最小原则，避免超出收集个人信息时所声明的目的和范围。
	权限声明和调用	检查APP以及集成的第三方SDK是否进行了权限声明。
	收集信息说明	检查APP以及集成的第三方SDK收集的个人信息是否在隐私政策内进行明示，应明确所收集个人信息的目的方式及使用范围，且APP应在隐私政策经过用户同意后方可进行相关个人信息收集。
源码安全	风险函数使用	检查APP是否存在高风险函数的使用。
	敏感信息泄露	检查APP源码中是否包含敏感信息、残留测试数据等，如内网URL地址、开发人员手机号、AK/SK密钥。
	漏洞修复	检查APP是否存在已知的高危漏洞和隐藏后门。
日志安全	敏感信息泄露	检查APP所产生的日志是否包含用户敏感信息，如会话标识、账户密码、手机号等。

附 录 B
(资料性)
Android APP 合规编码指南

Android APP开发过程中宜重点检查以下内容是否满足合规要求：

- a) 不应将 PermissionGroup 属性设置为空或者不使用 PermissionGroup。PermissionGroup 可以对 permission 进行逻辑上的分组。如果该属性为空，会导致权限定义无效，且其它 APP 无法使用该权限。
- b) 应将 allowBackup 属性设置为 false。在 AndroidManifest.xml 中，当这个标志被设置为 true 或不设置该标志位时，应用程序数据可被任意备份和恢复，adb 调试备份允许恶意攻击者复制应用程序数据。
- c) 应将 Debuggable 属性设置为 false。在 AndroidManifest.xml 中定义 Debuggable 项，如果该项被设置为 true，app 存在被恶意程序调试的风险，可能导致泄露敏感信息等问题。
- d) 如应用的组件不必要导出，应设置 Activity、Service、ContentProvider、BroadcastReceiver 组件的 android:exported 属性为 false。
- e) 应用内应严格对 openFile 方法访问的 URI 进行过滤，避免导致通过../方式实现的路径遍历，访问任意的目录文件，造成隐私泄露问题。
- f) 应限制使用隐式 Intent。恶意应用可能会劫持隐式 Intent，获取其中的敏感数据。
- g) 处理 Intent 数据时，比如通过 getXXXExtra() 获取数据时应进行异常判断，防止出现拒绝服务漏洞，包括：空指针异常、类型转换异常、数组越界访问异常、类未定义异常、其他异常。
- h) 使用 WebView 访问网站时，WebView 保存密码功能不应默认设置为 true，应使用 setSavePassword(false) 方法，禁止 WebView 明文存储密码。
- i) 使用 WebView 访问网站时，应使用 setAllowFileAccess(false) 方法，禁止 WebView 访问 File 域。如果应用 WebView 确实需要使用 File 域协议，应使用 setJavaScriptEnabled(false) 禁止 File 域协议调用 JavaScript。
- j) 应禁止使用未实现 verify 方法验证域名的自定义 HostnameVerifier 类。
- k) 应禁止使用未实现 checkClientTrusted、checkServerTrusted 方法的 X509TrustManager 类。
- l) 调用 setHostnameVerifier 方法时应禁止使用 ALLOW_ALL_HOSTNAME_VERIFIER 参数。
- m) 应禁止自定义实现的 WebViewClient 类在 onReceivedSslError 调用 handler.proceed() 方法来忽略该证书错误，当发生证书认证错误时，应采用默认的处理方法 handler.cancel()，停止加载问题页面。
- n) 在源码中应禁止硬编码私钥等敏感信息。
- o) 使用 getDir、getSharedPreferences(SharedPreference) 或 openFileOutput 方法时，应使用 MODE_PRIVATE 模式创建内部存储文件。
- p) 使用随机数时，禁止使用 SecureRandom 方法生成伪随机数。
- q) 发布应用时，应对 APP 进行加固，防止攻击者反编译获取应用代码导致数据泄露。

附 录 C
(资料性)
iOS APP 合规编码指南

iOS APP开发过程中宜重点检查以下内容是否满足合规要求:

- a) Xcode 工程应开启 PIE (ASLR) 安全设置以防止内存地址泄漏:
Build Settings->Apple Clang - Code Generation ->Generate Position-Dependent Code=NO,
Build Settings->Linking->Generate Position-Dependent Executable=NO,
Build Settings->Linking->Other Linker Flags 选项添加参数-fPIE。
- b) 在 Xcode 工程设置中应开启堆栈保护功能防止缓冲区溢出风险:
Build Settings->Linking->Other Linker Flags 选项添加参数 -fstack-protector-all。
- c) 不要使用私有 API, 使用苹果公布的 API。
- d) 使用 ARC 自动管理内存, 防止内存溢出:
Build Settings->Apple Clang - Language - Objective-C 设为YES。
- e) 在程序中不要使用 C 函数的 malloc 方法申请内存空间, 使用苹果封装好的方法和对象进行开发。
- f) 调用 ptrace 请求来检查应用是否被调试, 在 main() 添加 #ifndef DEBUG
ptrace(PT_DENY_ATTACH, 0, 0, 0); #endif, 或用 sysctl、syscall 等方式检测调试状态, 防止攻击者进行远程应用调试。
- g) 网络请求应使用 HTTPS, 正确配置 SSL 证书, 避免中间人攻击风险。
- h) 使用官方正版开发工具 Xcode, 切勿使用第三方修改的 Xcode 版本, 避免类似 XcodeGhost 漏洞。
- i) 使用最新版第三方解压库 SSZipArchive 或 Ziparchive, 避免 ZipperDown 路径穿越漏洞。
- j) 第三方网络请求库 AFNetworking, 应使用最新版, 避免证书校验漏洞。
- k) 沙盒内存储敏感信息(手机号、密码、身份证号码等)必须加密后存储, 不可明文存储。
- l) 对于存在敏感信息的界面, 应在 UIApplicationDelegate 的 applicationDidEnterBackground 中对后台快照做模糊处理, 防止信息泄露。
- m) 使用 AES 进行数据加密时, 不应使用不安全的 ECB 数据加密算法模式, 应使用 CBC 或 CFB 模式, 可带上 PKCS5Padding 填充。AES 密钥长度不应低于是 128 位, 宜使用 256 位。RSA 密钥长度不应低于 512 位。

参 考 文 献

- [1] GB/T 34975—2017 信息安全技术 移动智能终端应用软件安全技术要求和测试评价方法
- [2] YD/T 3447—2019 联网软件源代码安全审计规范
- [3] YD/T 3464—2019 联网软件安全编程规范



电信终端产业协会团体标准
移动互联网应用程序（APP）合规开发管理测评规范 第4部分：代码审计

T/TAF 209.4—2024

*

版权所有 侵权必究

电信终端产业协会印发
地址：北京市西城区新街口外大街28号
电话：010-82052809
电子版发行网址：www.taf.org.cn